

- **Authorisation:** Authorisation is a process to establish the right to perform transactions (actions), and claim access to assets and resources by a subscriber. In a blockchain application, the authorisation model should link the identity model and the authentication model. A good practice is to develop a multi-dimensional matrix of the account associated with identity, authentication and authorisation. This type of authorisation model will leave room to evolve into attribute based access control and role-based access control at the application level and, ultimately, at the organisational level, for enterprise blockchain applications. The authorisation model will typically address concepts such as separation of duties (SoD).
- **Web application security:** Web application security should include protection against vulnerabilities identified in OWASP (Open Web Application Security Project) Top 20.

Identity and access management

layer: A digital identity is a unique representation of a person or thing engaged in a digital transaction. Identity proofing, or enrolment, is the physical or digital process of verifying a subject's association with his/her real-world identity. An identity model and its associated identity proofing should provide reasonable assurance for the identity claimed by the subject. When the trust attributes of the blockchain application range from public to private, it is good practice to have multiple assurance levels for identity-proofing.

Application/data layer: The application security layer should ensure the following:

- Smart contracts and the blockchain processing platform are vetted to prevent things like calls to the unknown, valueless send, exception disorders, type casts, re-entrants, keeping secrets, immutable bugs,

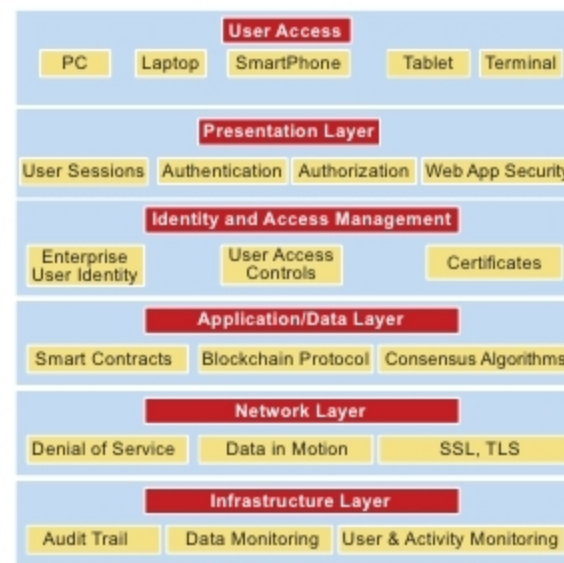


Figure 1: Security architecture with blockchain

value (ether) lost in transfer and stack size limits.

- Blockchain protocols are vetted to prevent the blockchain from not converging as expected or into an unpredictable state, safeguarding the seed (genesis) block and ensuring timestamps are adequately protected.
- Consensus algorithms that enable transparency by imposing a transaction order to be correct for a new block added to the blockchain. This ensures that all the nodes in the network are in agreement on the new transactions added to the block.

Network layer: Depending on the nature of the application and the type of the network (Internet-based, leased lines, virtual private network, etc), there should be appropriate controls extracted from the system. Controls related to boundary protection (data-in-motion) and denial of service (DoS) should be considered.

Infrastructure layer: *Audit trail* is for all the transactions that will be maintained by the blockchain. Transactions ordering and approval will be done by the consensus service on board. This ensures that the transactions are correct and transparent to other participants/nodes in the network.

Data protection: Data protection is the process of safeguarding important information or data from corruption, compromise or loss. As blockchain is immutable, data cannot be compromised and appropriate measures like redundancy can be taken to protect

it from corruption and loss.

User and activity monitoring: All valid transactions performed by users can be tracked on blockchain. User onboarding and management will be done by membership service shipped along with the blockchain.

Types of blockchains

Blockchains are classified as public, private or hybrid depending on the nature of the application. Public and private blockchains share many similarities as well as differences in their functionality.

Here is a quick comparison between them, based on some recent functionality.

Public blockchain: This is completely open to the public, so anyone can join the network as a participant. A public blockchain typically uses some kind of mechanism to incentivise participating parties, which encourages a growing number of participants in the network. A public blockchain is open for everyone to read, send transactions and participate in the consensus process. The most prominent examples are the blockchains underlying Bitcoin and Ethereum.

Anyone can participate in a public blockchain, because it is open source and free to all, with no one in charge. There is no access or rights management done for a public blockchain and anyone can be a part of the consensus process. Because of this, anyone at any given point of time can join or leave, read, write or audit the public blockchain ecosystem, and the network will still be trusted.

Private blockchain: The private blockchain is the absolute opposite of the public version. The access to a private blockchain is limited to those involved in the creation of that particular network, or those granted access to it by the creators. The internal mechanics of a private blockchain can vary, from existing participants serving as types of administrators who decide on the inclusion of future entrants, to simple observers, but the public cannot access the private blockchain.